

Risk register Trial Project

Operational environment:

The bank is located in a coastal area with low crime rates. Many people and systems handle the bank's data—100 on-premise employees and 20 remote employees. The customer base of the bank includes 2,000 individual accounts and 200 commercial accounts. The bank's services are marketed by a professional sports team and ten local businesses in the community. There are strict financial regulations that require the bank to secure their data and funds, like having enough cash available each day to meet Federal Reserve requirements.

Asset	Risk(s)	Description	Likelihood	Severity	Priority	CIA Impact	NIST CSF Function
Funds	Business email compromise	<i>An employee is tricked into sharing confidential information.</i>	Medium	Medium	Medium	C, I	Govern, Protect and Detect
	Compromised user database	<i>Customer data is poorly encrypted.</i>	Medium	High	Critical	C, I	Govern and Protect
	Financial records leak	<i>A database server of backed up data is publicly accessible.</i>	High	Medium	Critical	C	Govern, Protect and Detect
	Theft	<i>The bank's safe is left unlocked.</i>	Low	High	Medium	C, A	Govern, Protect and respond
	Supply chain disruption	<i>Delivery delays due to natural disasters.</i>	Medium	Low	Low	A	Govern, Identify and Recover

Notes	Possible risks in the operating environment: 1. Business email compromise: The bank has <i>100 on-premises employees</i> and <i>20 remote employees</i>. On-premises employees benefit from the bank's internal security infrastructure, including stronger network security controls due to their physical presence within the organization's managed environment. Remote employees are provided with security measures such as endpoint protection, VPN access, and other risk mitigation tools. However, they continue to access organizational resources through home networks, which are outside the bank's direct control and may present additional security risks. In the event of a successful Business Email Compromise (BEC), attackers may obtain employee email credentials, allowing unauthorized access to corporate mailboxes and the most likely information exposed would include <i>operational data, internal business communications, strategic plans, and</i>
-------	---

organizational information. Based on the current environment, **customer data is not expected to be directly compromised**, as it is protected through separate security controls and access restrictions.

2. **Compromised user database:** The bank is in compliant with the financial regulations to secure their data. So, the likelihood of risk is moderate yet a user data compromise possesses **high severity** due the nature of data involved such as the *username, passwords and other PII data*. It attracts severe penalty from the Federal and the customers should be compensated under the breach insurance. Along with these, the reputation of bank is compromised. So, the encrypted data should be equipped with *depth-in-defense (such as use of MFA, timely patch management, continuous monitoring and etc.,)* and encryption standard should be met with the Federal requirements.

Since the bank is associated with a sports team and ten local business community for marketing services. They share limited customer information for marketing and out-reach purposes. If a marketing provider that stores the bank's limited customer data fails to implement adequate encryption standards or uses software that does not comply with the bank's security requirements, the risk of unauthorized access and subsequent data exfiltration increases. So, the vendor risk assessment with compliance verification and security assessments must be in place to avoid data exfiltration.

3. **Financial records leak:** The requirement of using back-up server will offer business continuity for the bank in the event of server crash or security related incidents. However, misconfigured backup servers, improper storage configurations, or inadequate privilege-based access controls could result in unauthorized access to sensitive financial records. Such a breach could lead to regulatory penalties, financial losses and reputational damage

The bank's security needs to identify the assets they hold in the environment and based on sensitivity or availability, proper controls should be implemented to support the compliance. These backup data servers, *should ideally be isolated from the operational environment* and should not be public facing.

4. **Theft:** The bank is surrounded with low crime environment and it naturally benefits from less physical thefts. So, the likelihood is less yet the threat actors are not limited to the particular regions and severity is high. So physical security hardening with required personal, use of vaults to secure cash and sensitive documents and monitoring tools should be in place. The bank's campus should be easily reachable by the local police forces within stipulated buffer time to counter on theft in case of such events.
5. **Supply chain disruption:** The bank is situated in the coastal area where natural calamities can cause disruption in organizational operation with un-informed power outages, transfer of cash through vehicle and infrastructural damage. Yet the natural calamities are seasonal oriented, so with pre-planned federal approved cash reserves and disaster management protocol in place, this disruption can be limited.